



# ShieldAI

**The Virtual CISO Platform**

*Affordable today. A managed-security platform at scale.*

## **COMPREHENSIVE BUSINESS PLAN**

*Consolidated with Market Analysis, Competitive Analysis & Financial Model*

Confidential · 2026

Prepared by Xandu Limited, LLC

# Contents

1. Executive Summary
2. The Problem & Market Opportunity
  - 2.1 The SMB Security Gap
  - 2.2 Market Size & Headline Figures
  - 2.3 Market Sizing (Bottom-Up: TAM / SAM / SOM)
  - 2.4 Why Now
3. Product & Platform
  - 3.1 What the Customer Gets
  - 3.2 The Scoring Engine — Our Core IP
  - 3.3 The Role of AI
4. Strategy: Wedge to Platform
5. Business Model
  - 5.1 Revenue Streams
  - 5.2 Pricing Tiers
  - 5.3 Unit Economics — The Scalability Engine
6. Financial Projections
7. Competitive Landscape & Defensibility
  - 7.1 The Landscape
  - 7.2 Detailed Competitor Profiles
  - 7.3 Head-to-Head Comparison
  - 7.4 Why We Win
  - 7.5 Competitive Risks & Watch Items
8. Marketing & Customer Acquisition Strategy
  - 8.1 Target Customer & Positioning
  - 8.2 Acquisition Channels
  - 8.3 Lifecycle & Expansion Marketing
  - 8.4 Metrics & Marketing Discipline
9. Product Roadmap & Future Vision
10. Founder & Team
11. The Ask & Use of Funds
12. Risk Analysis & Mitigation
13. Summary

# 1. Executive Summary

*A full-time CISO costs \$200,000–\$400,000 a year. Nearly half of small businesses have no security budget at all — yet their insurers, customers, and regulators now require a real security program. ShieldAI closes that gap.*

ShieldAI is a virtual Chief Information Security Officer (vCISO) platform for small and mid-sized businesses (SMBs). It delivers a complete, continuously-managed security program — risk scoring, written policies, a prioritized roadmap, compliance mapping, awareness training, and executive reporting — at a price a small business can afford.

Our strategy is a deliberate wedge-to-platform progression. We begin with a free assessment and an affordable, largely self-serve tier ladder that delivers immediate value and proves the model. As clients grow, we layer human expertise on top: cybersecurity engineers who use ShieldAI to run full, managed CISO programs for a portfolio of clients — with the software (and an AI co-pilot) doing the heavy lifting so a small team can protect a large book of businesses. This is how we move from a low-cost tool to a high-value managed-security platform without a linear increase in headcount.

ShieldAI is powered by frontier AI for analysis and content generation, but our defensibility does not rest on the AI itself. It rests on four things: a proprietary, deterministic security-scoring engine built on the NIST Cybersecurity Framework that produces explainable, auditor- and insurer-trustworthy results; a human-in-the-loop model in which qualified engineers review and approve work before it reaches the client; the proprietary assessment data and client relationships that compound over time; and direct-to-SMB distribution at a price point the market's best-funded players — Cynomi, Vanta, Drata, Secureframe, and Scrut Automation — have each left structurally uncontested (see Section 7).

This document consolidates ShieldAI's full investor picture into a single reference: the business plan, sourced market analysis, detailed competitive profiles, and financial model outputs, alongside a customer-acquisition strategy, an expanded product vision, and the founding team.

## Key Highlights

| Metric                 | Detail                                                                                                                                                    |
|------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Target market</b>   | U.S. SMBs with employees, prioritizing regulated and insured segments                                                                                     |
| <b>Core category</b>   | Virtual CISO (vCISO) — ~\$2B+ today, growing 12–15%+ annually                                                                                             |
| <b>Demand driver</b>   | Cyber-insurance, customer security requirements, and regulation forcing SMBs to act                                                                       |
| <b>Model</b>           | Five-tier ladder — Free \$0 / Starter \$159 / Growth \$349 / Guided \$699 / Managed vCISO \$1,950 — land-and-expand into engineer-run managed programs    |
| <b>Differentiation</b> | Deterministic NIST scoring engine + human-in-the-loop + direct-to-SMB reach nobody else in the category has                                               |
| <b>Unit economics</b>  | \$0.28/client/month AI cost; blended gross margin expanding from ~12% (Y1) to ~74% (Y3)                                                                   |
| <b>Stage</b>           | Working product live in production — assessment, scoring, program & policy generation, 12 compliance frameworks, billing infrastructure, monitoring agent |
| <b>Team</b>            | Founder-led, with a part-time engineer already contributing and ready to convert full-time once funded (see Section 10)                                   |

| Metric                | Detail                                                                                          |
|-----------------------|-------------------------------------------------------------------------------------------------|
| <b>Next milestone</b> | Convert the analyst console from mockup to live; bring the first security engineer on full-time |

*This plan reflects ShieldAI's current direction: the self-serve product is built and functioning in production; this raise funds the build-out of the managed-services platform layer that turns it into a scalable business.*

## 2. The Problem & Market Opportunity

### 2.1 The SMB Security Gap

Small businesses face the same threat landscape as enterprises — ransomware, phishing, business email compromise, supply-chain attacks — but lack the budget, expertise, or time to respond. They are caught in a structural bind: too big to ignore security, too small to afford a dedicated leader. A full-time CISO costs \$200,000–\$400,000 or more per year, while the foundational tools and expertise cost roughly the same whether a business has 10 employees or 100 — so the per-employee burden falls hardest on the smallest firms.

- 47% of businesses with fewer than 50 employees have no cybersecurity budget at all (StrongDM / CrowdStrike, 2025).
- 51% have no security measures in place; one-third rely on free, consumer-grade tools.
- Only 34% have a formal incident response plan (Guardz, 2025).
- Only ~13% conduct proactive security audits, and only ~1 in 5 performs annual penetration testing.
- Small businesses represent roughly 43% of all cyberattacks, and SMB incident rates rose ~47% year over year.

The cost of inaction is severe and quantifiable: IBM data shows a tested incident-response plan reduces breach cost by approximately \$232,000, and prevention investment returns consistently exceed 7x. A foundational program costing \$5,000–\$15,000 a year would save hundreds of thousands in the event of a breach — yet the businesses that spend nothing are the ones that pay the most.

### 2.2 Market Size & Headline Figures

*ShieldAI sits in the virtual CISO category, inside the broader SMB cybersecurity market. The figures below are sourced for direct citation in investor conversations — when pressed on a number, estimates range from X to Y depending on how you scope it; here's the source I'm using is a stronger answer than a single suspiciously-precise figure.*

| Metric                                            | Figure                                                   | Source                       |
|---------------------------------------------------|----------------------------------------------------------|------------------------------|
| US small businesses                               | <b>36.2 million (99.9% of all US businesses)</b>         | SBA Office of Advocacy, 2025 |
| — of which have employees                         | <b>~5.8M employer firms (30.4M are solo/nonemployer)</b> | SBA Office of Advocacy, 2025 |
| SMBs with no cybersecurity budget (<50 employees) | <b>47%</b>                                               | StrongDM / CrowdStrike, 2025 |
| SMBs with no security measures at all             | <b>51%</b>                                               | StrongDM, 2025               |
| SMBs with a formal incident response plan         | <b>only 34%</b>                                          | Guardz, 2025                 |
| Global SMB cybersecurity spending (by 2026)       | <b>\$109 billion, growing ~10%/yr</b>                    | Analysis Mason               |

| Metric                                | Figure                                   | Source                         |
|---------------------------------------|------------------------------------------|--------------------------------|
| vCISO market (2025)                   | ~\$2.0–2.9B, growing 15%+ CAGR           | Multiple research firms        |
| U.S. cyber-insurance market           | ~\$3.9B (2025), ~22% CAGR                | Market Research Future         |
| Full-time CISO cost                   | \$200K–\$400K+/year                      | Industry standard              |
| Avg. data breach cost, small business | ~\$120K (some sources cite far higher)   | Total Assure, 2025             |
| Cyber positions unfilled globally     | 3.4 million                              | Industry (talent shortage)     |
| ShieldAI pricing ladder               | \$0 (Free) to \$1,950/mo (Managed vCISO) | ShieldAI production, July 2026 |

*vCISO market estimates vary by research firm — from roughly \$1.06B to \$2.89B for 2024–25, with forecasts ranging from \$1.5B to \$12B by the early 2030s — because firms scope the category differently (some include only software, others include the full advisory/consulting spend). Every credible source agrees on direction: double-digit annual growth, driven by escalating threats, a 3.4-million-person global cybersecurity talent shortage, and tightening compliance.*

### 2.3 Market Sizing (Bottom-Up: TAM / SAM / SOM)

- TAM: The global vCISO category, ~\$2B+ and growing 12–15%+ per year — the market we directly serve.
- SAM: ~5.8M U.S. employer businesses, narrowed to regulated/insured/supply-chain segments (a conservative 10–20% → roughly 600K–1.2M businesses). At a blended program value in the low thousands per year, this is a multi-billion-dollar serviceable market.
- SOM: A modest, credible early capture — e.g., 1% of a 600K-business SAM at a few thousand dollars per year per client — represents a business on the order of \$20M+ in annual recurring revenue, reached over a 3–5 year horizon via the free-to-managed motion.

*For reference, the 3-Year Financial Model (Section 6) projects ~1,610 total paying clients and ~\$10.1M in annualized ARR by the end of Year 3 — roughly 0.1–0.3% of the conservative SAM, well inside the SOM range above.*

### 2.4 Why Now

The decisive shift is that demand is no longer driven by whether small businesses care about security, it is being forced on them by three external pressures converging at once:

- Cyber-insurance as gatekeeper: Insurers now require proof of specific controls (MFA, incident response, etc.) before issuing or renewing policies. 63% of SMBs saw premiums rise 200%+ in 2025, and businesses under \$25M in revenue filed 64% of all cyber-insurance claims — so insurers are tightening precisely on our target segment.
- Customer-driven requirements: Larger customers increasingly push security questionnaires and insurance requirements down to their small vendors. Without a demonstrable program, small businesses lose contracts.
- Expanding regulation: HIPAA, CMMC (defense supply chain), the FTC Safeguards Rule, and state privacy laws now carry real penalties — reaching deep into the small-business tier.

On the supply side, AI has only recently become capable enough to deliver expert-level security analysis and documentation at a cost that makes serving the small-business segment economically viable. The need and the means have arrived at the same moment.

## 3. Product & Platform

### 3.1 What the Customer Gets

From a short, structured assessment, ShieldAI produces a complete security program through a unified dashboard:

- Security assessment: a conversational intake plus a structured, NIST-mapped checklist that captures the business's context and current posture.
- Deterministic risk score: an explainable security-posture score (see 3.2) with a per-function breakdown.
- Prioritized roadmap: ranked actions with effort, impact, cost, and ownership — including immediate quick wins.
- Professional policy library: complete, formatted, ready-to-use policy documents (Acceptable Use, Incident Response, Access Control, Data Classification, and more), downloadable as Word files and tailored to the business.
- Compliance mapping: gap analysis against the frameworks relevant to the business — 12 frameworks supported today, including HIPAA, PCI DSS v4.0, SOC 2, CMMC 2.0, ISO 27001, and NIST 800-171 — with remediation guidance.
- Incident response workflows, a recommended tool stack, a standalone awareness-training product, board-ready executive reporting, and Mastermind AI Q&A — live at the Starter tier and up, scoped to what that client's plan includes and to their own data only.

### 3.2 The Scoring Engine — Our Core IP

ShieldAI's differentiator is a deterministic risk-scoring engine built on the NIST Cybersecurity Framework. Unlike an AI that guesses a number, the engine computes a posture score across the five NIST functions — Identify, Protect, Detect, Respond, and Recover — each weighted and scored from the structured assessment. The same inputs always produce the same score, and every point traces to a specific control.

This matters commercially: an insurer, auditor, or enterprise customer can trust an explainable, repeatable score in a way they would never trust an opaque AI output. The scoring methodology is proprietary and improves as our assessment dataset grows. A CI-enforced integrity guard fails the build if any framework's control mapping lacks a documented scoring method — 96% of supported frameworks are fully assessed today, with zero unbacked claims shipped to clients.

### 3.3 The Role of AI

Frontier AI powers the analytical and generative work — interpreting the assessment, drafting tailored policies, generating training and reporting, and (in the platform layer) assisting our engineers. The architecture is model-flexible and routes work to the model best suited to it: Anthropic's Claude for reasoning and writing, Google Gemini for threat intelligence and search grounding, and OpenAI's GPT-4o for tool recommendations and training content. Crucially, the AI accelerates expert work rather than replacing expert judgment — which is central to both our quality bar and our liability posture (see Section 9 for how this evolves).

## 4. Strategy: Wedge to Platform

### 4.1 The Wedge — Self-Serve Product

The entry point is a free assessment, followed by an affordable, largely self-serve tier ladder. A business completes an assessment, receives a real posture score and a complete program, and can generate and download professional policies — immediate, tangible value at a fraction of the cost of a consultant. This wedge gets businesses in the door at zero-to-low cost, proves the model, and builds the assessment dataset that strengthens our scoring engine.

## 4.2 The Expansion — Managed vCISO Programs

As clients grow or face greater compliance demands, they graduate to managed plans in which a ShieldAI cybersecurity engineer runs their security program on an ongoing basis. This is higher-value, higher-retention recurring revenue, and it is where the human-in-the-loop model delivers both quality and trust.

## 4.3 The Platform — The Analyst Console

The engine of scale is an internal analyst console: a command center where each engineer manages a portfolio of client businesses, strictly scoped to their assigned clients only. From a single interface an engineer monitors every client's posture and trend over time, sees live alerts from read-only monitoring agents deployed in client networks, communicates directly with clients, and reviews and approves the AI's work before it ships. An integrated AI co-pilot — ShieldAI Mastermind — is strictly advisory: it triages threats, diagnoses issues, and surfaces compliance gaps, but has no inbound command channel and cannot act on a client's environment. One engineer can do what previously required a whole team, without ever giving the AI the ability to act unilaterally.

A working mockup of this console exists today; converting it into a live, agent-fed product is a primary objective of this raise. This is the layer that transforms cybersecurity consulting from a headcount-bound business into a scalable platform.

*The AI does the first 80%. The engineer adds the high-value 20% — judgment, accountability, and the client – vendor relationship. That blend is our margin and our quality bar.*

# 5. Business Model

## 5.1 Revenue Streams

- Self-serve subscriptions (Starter, Growth) — low-cost, high-volume entry tiers; the wedge.
- Guided subscriptions — self-serve plus periodic engineer touch, the bridge to fully managed.
- Managed vCISO plans — engineer-run programs; the primary recurring-revenue engine.
- Training delivery add-on — \$40/month standalone add-on for Starter clients; bundled free at Growth tier and above.
- Channel / partnerships — referrals from cyber-insurers, MSPs, and professional-services firms whose clients are required to demonstrate controls (expanded in Section 8).
- Add-ons — compliance-readiness packages, cyber-insurance documentation, and specialized policy work.

## 5.2 Pricing Tiers

Pricing is set to undercut traditional human-only vCISO retainers — which typically run \$2,500–\$11,600/month for SMB clients — while remaining more complete than automated-only tools. Because AI performs the heavy lifting at a measured cost of \$0.28 per client per month, ShieldAI can offer a free entry point and price every paid tier for real SMB budgets while still holding healthy margins as the business scales (see 5.3).

| Tier | Price / mo | What it includes                           | Target customer                    |
|------|------------|--------------------------------------------|------------------------------------|
| Free | \$0        | Security assessment and posture score only | Top-of-funnel; zero-friction entry |

| Tier                 | Price / mo     | What it includes                                                                                    | Target customer                         |
|----------------------|----------------|-----------------------------------------------------------------------------------------------------|-----------------------------------------|
| <b>Starter</b>       | <b>\$159</b>   | Full program generation, policy library, endpoint monitoring, and Mastermind Q&A — no engineer time | Micro-businesses; the wedge             |
| <b>Growth</b>        | <b>\$349</b>   | Expanded policy and endpoint coverage, full training program access, downloads/exports              | Growing SMBs formalizing their program  |
| <b>Guided</b>        | <b>\$699</b>   | Growth, plus periodic engineer review, compliance tracking, and check-ins                           | SMBs with active compliance needs       |
| <b>Managed vCISO</b> | <b>\$1,950</b> | A ShieldAI engineer runs the security program end-to-end, with full Mastermind access               | Regulated / insured / supply-chain SMBs |

*A \$40/month training delivery add-on — tokenized learner links, quarterly scheduling, and fleet-wide reporting — is available on Starter and bundled free at Growth tier and above. Mastermind Q&A is included Starter tier and up, scoped strictly to each plan's accessible features and to that client's own data.*

The ladder is designed for land-and-expand: a business can start at \$0 and grow into managed plans as trust builds and compliance demands increase. The Managed tier deliberately sits at or below the bottom of the traditional retainer range — a fractional CISO at a fraction of the cost.

### 5.3 Unit Economics — The Scalability Engine

The defining economics are at the Managed tier, where the analyst console and AI co-pilot let a single cybersecurity engineer manage roughly 25 clients with a high-touch service level.

| Metric                          | Value                                                       |
|---------------------------------|-------------------------------------------------------------|
| Managed price                   | <b>\$1,950 / month</b>                                      |
| Clients per engineer            | <b>~25 (enabled by the AI-amplified console)</b>            |
| Revenue per engineer            | <b>~\$585,000 / year</b>                                    |
| Fully loaded engineer cost      | <b>~\$140,000 / year</b>                                    |
| AI + infrastructure cost        | <b>\$0.28 / client / month (measured production figure)</b> |
| Gross contribution per engineer | <b>~\$445,000 / year (~76% margin)</b>                      |

*This corrects an earlier planning estimate that assumed \$15/client/month in AI cost — roughly 50x the measured figure. At the per-engineer level, AI cost is now immaterial (~\$84/year against \$585,000 in revenue), and the gross-contribution margin is a function almost entirely of engineer utilization, not AI spend.*

Because the company carries real payroll (product engineers, leadership, sales & marketing, and G&A) ahead of revenue in the early months, the blended, company-wide margin is lower than the per-engineer figure above and expands over time:

| Blended Margin       | Year 1  | Year 2 | Year 3 |
|----------------------|---------|--------|--------|
| <b>Gross Margin</b>  | ~12%    | ~58%   | ~74%   |
| <b>EBITDA Margin</b> | ~(147)% | ~2%    | ~44%   |

*This is the crux of the investment thesis: revenue scales with the client book while engineer headcount grows far more slowly, because the software does the heavy lifting. See Section 6 and the companion 3-Year Financial Model workbook for the full monthly build.*

## 6. Financial Projections

The following is an illustrative three-year ramp built from a full monthly model (see the companion 3-Year Financial Model workbook), reflecting the five-tier pricing ladder, measured AI costs, and a founder-planned headcount build.

|                                     | Year 1  | Year 2  | Year 3   |
|-------------------------------------|---------|---------|----------|
| Free clients (top of funnel)        | 500     | 1,800   | 4,500    |
| Starter clients                     | 90      | 300     | 750      |
| Growth clients                      | 40      | 150     | 400      |
| Guided clients                      | 25      | 100     | 260      |
| Managed clients                     | 15      | 60      | 200      |
| Total paying clients                | 170     | 610     | 1,610    |
| Team headcount (all roles)          | 5       | 13      | 23       |
| Revenue (full year)                 | ~\$0.3M | ~\$2.0M | ~\$6.5M  |
| ARR (annualized run-rate, year-end) | ~\$0.9M | ~\$3.5M | ~\$10.1M |
| Gross Margin                        | ~12%    | ~58%    | ~74%     |
| EBITDA Margin                       | ~(147)% | ~2%     | ~44%     |

Full-year revenue and year-end ARR run-rate are shown separately because the client base ramps throughout each year. The key dynamic: Year 3 ARR is roughly 11x Year 1 ARR while headcount grows less than 5x — the signature of a platform rather than a consultancy.

Under this plan, the \$900,000 seed raise (Section 11) is never fully exhausted — modeled cash reaches its low point of roughly \$130,000 around Month 18 before the business turns cash-flow positive, consistent with Series A readiness in the Month 22–24 window.

The companion 3-Year Financial Model workbook (referenced throughout this plan) contains the full monthly build across seven linked tabs — Assumptions, Client Growth Model, Headcount & Payroll, Monthly P&L, Annual Summary, Cash Flow & Runway, and Unit Economics — so every figure above can be traced back to its driving assumption.

## 7. Competitive Landscape & Defensibility

### 7.1 The Landscape

The five most-cited names in vCISO and GRC software split into two categories, neither of which sells directly to a small business at a small-business price.

- AI-native vCISO platform, sold through service providers: Cynomi — the small business never sees or chooses it.
- Compliance / GRC automation, sold to venture-funded technology companies: Vanta, Drata, Secureframe, and Scrut Automation — priced and built for cloud-native startups chasing an audit, not Main Street SMBs.

Every well-funded name in the category sells either through a service-provider channel or to venture-funded technology companies at 4–50x ShieldAI's price. None is built, priced, or staffed to win a direct small-business sale today — that gap is the market ShieldAI is built for.

## 7.2 Detailed Competitor Profiles

### Cynomi

**Category:** AI-native vCISO platform for MSPs, MSSPs, consultancies, and telcos

**Founded / HQ:** 2020, Tel Aviv, Israel — with offices in the UK and USA

**Funding:** \$37M Series B, April 2025 (Insight Partners, Entrée Capital co-lead; Canaan, Flint Capital, S16VC participating). Reported 3x ARR growth in 2024, 4.5x in 2023

**Target Customer:** The service provider (MSP/MSSP), not the end small business

**Pricing Model:** Per-seat / per-client platform licensing sold to the MSP; never billed to the small business directly

**Strengths:** the category leader by funding, growth, and brand recognition among MSPs; turns CISO-level methodology into guided workflows a non-security technician can execute; broad and fast-expanding framework coverage.

**Why it doesn't compete directly with ShieldAI:** Cynomi has no direct-to-small-business product or brand presence; its output quality depends on the MSP operating it, whereas ShieldAI's engineers review every deliverable; and its wholesale distribution model is structurally difficult to reverse into a direct-to-business motion without channel conflict with its own MSP customers.

### Vanta

**Category:** Compliance automation / GRC platform

**Target Customer:** Venture-funded technology companies pursuing SOC 2, ISO 27001, or HIPAA for enterprise sales

**Pricing:** Quote-based; 2026 street pricing runs roughly \$10,000–\$80,000+ per year

**Strengths:** the most recognized name in the compliance-automation category, with the widest native integration library; strong self-serve trust-report and continuous-monitoring experience for engineering-led teams.

**Why it doesn't compete directly with ShieldAI:** priced and built for companies with a cloud engineering stack to connect, not a 20-person medical practice with on-prem systems and no dedicated IT staff; delivers evidence collection and a trust report, not a full CISO program — no tailored written policies, no prioritized remediation roadmap, no ongoing human-led program management; no published, small-business-accessible price point.

### Drata

**Category:** Compliance automation / GRC platform

**Target Customer:** Engineering-heavy startups needing deep automation and a smooth audit workflow, primarily for SOC 2

**Pricing:** Quote-based; 2026 street pricing runs roughly \$7,500–\$100,000+ per year

**Strengths:** strong auditor network and Audit Hub workflow that reduces back-and-forth during a formal audit; deep integration count (300+) valuable for complex technical stacks.

**Why it doesn't compete directly with ShieldAI:** the same structural mismatch as Vanta — built for a company with an engineering stack to monitor, not a small business whose gap is policy, process, and a security roadmap it can actually execute; no human-delivered program management.

### Secureframe

**Category:** Compliance automation / GRC platform

**Target Customer:** First-time compliance teams and smaller startups wanting a guided, hand-held path to SOC 2 or ISO 27001

**Pricing:** Two plans (Fundamentals and Complete); 2026 street pricing starts around \$7,500/year and runs past \$80,000/year

**Strengths:** the most guided, hand-holding onboarding of the three major compliance platforms; includes some advisory/consulting touch in its packages.

**Why it doesn't compete directly with ShieldAI:** still priced and scoped for a technology company chasing an audit, not a Main Street small business managing insurer and regulator pressure; guided means guided through a compliance audit workflow, not an ongoing, engineer-reviewed security program with policies, training, and executive reporting.

### Scrut Automation

**Category:** AI-powered GRC / multi-framework compliance automation

**Founded:** 2021; global operations spanning the US and India

**Funding:** \$20.5M total raised, including a \$10M round in 2024 (Lightspeed, MassMutual Ventures, Endiya Partners)

**Target Customer:** 50–500 employee mid-market SaaS companies pursuing multiple compliance frameworks at once

**Pricing:** Quote-based; typical platform cost runs roughly \$15,000–\$40,000/year, bundling frameworks and modules

**Strengths:** bundled multi-framework pricing is a genuine advantage for a company juggling SOC 2, ISO 27001, and HIPAA at once; AI-assisted remediation guidance (Scrut Teammates) is a real automation step beyond pure evidence collection.

**Why it doesn't compete directly with ShieldAI:** explicitly positioned above early-stage-startup pricing and below late-stage enterprise pricing — the mid-market SaaS sweet spot, not the small, non-technology business ShieldAI serves; requires meaningful GRC background to configure.

## 7.3 Head-to-Head Comparison

| Company          | Buyer                         | Typical Annual Price                 | Delivery Model                      | Human Oversight                   | Direct to SMB? |
|------------------|-------------------------------|--------------------------------------|-------------------------------------|-----------------------------------|----------------|
| Cynomi           | MSP / MSSP                    | Not sold to SMB                      | Platform + MSP labor                | Varies by MSP                     | No             |
| Vanta            | VC-funded tech co.            | \$10K–\$80K+                         | Self-serve platform                 | None (self-serve)                 | No             |
| Drata            | VC-funded tech co.            | \$7.5K–\$100K+                       | Self-serve platform                 | None (self-serve)                 | No             |
| Secureframe      | VC-funded tech co.            | \$7.5K–\$80K+                        | Guided platform                     | Light advisory add-on             | No             |
| Scrut Automation | Mid-market SaaS               | \$15K–\$40K                          | Self-serve platform                 | None (self-serve)                 | No             |
| <b>ShieldAI</b>  | <b>Small business, direct</b> | <b>\$0–\$23,400 (\$0–\$1,950/mo)</b> | <b>AI program + engineer review</b> | <b>Every deliverable reviewed</b> | <b>Yes</b>     |

## 7.4 Why We Win

- Proprietary scoring methodology: explainable, repeatable, and trusted by insurers and auditors — not an opaque AI guess.
- Human-in-the-loop: expert review makes output trustworthy enough to sell and materially limits liability — a layer none of the four self-serve compliance platforms above offer at any price.
- Compounding data and relationships: every assessment and managed client makes the system smarter and stickier.
- Direct-to-SMB reach at an SMB price: the lane every well-funded competitor above has left structurally open — Cynomi sells through MSPs, and Vanta/Drata/Secureframe/Scrut sell to venture-funded technology companies at 4–50x ShieldAI's price.
- The AI is the commodity; the system around it — methodology, workflow, engineers, data, and direct distribution — is the moat. A well-funded competitor cannot trivially replicate the whole system.

## 7.5 Competitive Risks & Watch Items

- Cynomi expanding downstream: with \$37M in fresh capital and 3x ARR growth, Cynomi could plausibly launch a direct-to-business SKU. Its MSP-channel economics and brand make this a real but not immediate threat — worth monitoring each funding/product announcement.
- A stripped-down SMB tier from Vanta, Drata, or Secureframe: all three have signaled downward price pressure from smaller entrants; a simplified, lower-priced SKU aimed at smaller companies is conceivable within 12–24 months.
- New AI-native entrants: the compliance-automation category is attracting well-funded challengers (Sprinto, Thoropass, ComplyJet, Hyperproof) that could eventually target true SMBs; none currently does, but the category is moving fast.
- Mitigation: ShieldAI's moat is the combination — deterministic scoring, human review, and direct SMB distribution — not any single feature a competitor could copy in isolation. Speed of client and data accumulation, plus the feature-depth roadmap in Section 9, is the best defense against a fast-follower.

## 8. Marketing & Customer Acquisition Strategy

ShieldAI's acquisition strategy is built around a simple insight from Section 2.4: our buyer is rarely searching for security out of general concern. They act when an external party — an insurer, a customer, a regulator — forces the question. Marketing's job is to be present at that moment of forced decision, and priced low enough that the free assessment removes any reason to delay.

### 8.1 Target Customer & Positioning

The primary buyer is an owner, office manager, or operations lead at a 10–250 employee business in a regulated, insured, or supply-chain-exposed vertical — healthcare practices, financial advisories, manufacturers, and similar professional and operational businesses. This buyer is not a security expert, is budget-conscious, and is almost always triggered into action by an external requirement rather than proactive interest.

Positioning leads with the trigger, not with fear: The security program you're being asked to prove you have — without hiring a CISO. Messaging is anchored to the specific forcing function (an insurance renewal, a customer's security questionnaire, a compliance deadline) rather than generic cybersecurity anxiety, which this buyer has learned to tune out.

## 8.2 Acquisition Channels

Channels are prioritized by intent and cost, cheapest and highest-intent first:

- Cyber-insurance broker & carrier partnerships — the single highest-intent channel, since insurers are already requiring these controls (Section 2.4). Partner with regional brokers and MSP-adjacent insurance MGAs to become the vendor a broker recommends when a client's application is denied or a premium spikes for lack of controls.
- Referral partnerships with adjacent, non-competing professionals — accountants, business attorneys, and MSPs/IT providers who serve the same SMBs but don't offer a dedicated security program. A modest referral fee or revenue share for a warm introduction is far cheaper than paid acquisition, and these referral partners are motivated to keep their clients out of trouble, not to compete with us.
- Vertical trade association partnerships & sponsorships — dental and healthcare-practice associations, community bank and credit union associations, manufacturer trade groups (tied directly to CMMC deadlines), and financial-advisor associations. These are dense, pre-qualified audiences that map directly onto the compliance frameworks already built (HIPAA, CMMC, SEC/SOC 2).
- Compliance-deadline-driven content & campaigns — timed campaigns around known regulatory triggers (CMMC rollout phases, state privacy law effective dates, FTC Safeguards Rule enforcement actions) create urgency without resorting to fear-based generic messaging.
- SEO & content marketing around the free assessment — since the wedge is the free assessment itself, invest in content that ranks for the exact searches this buyer makes when the trigger hits (do I need a HIPAA risk assessment, CMMC requirements for small manufacturers, what does my cyber insurance policy require), routing directly to the assessment as the call to action.
- Narrowly-targeted paid search & social — small, tightly-scoped campaigns on the highest-intent search terms and vertical-specific channels, measured strictly against free-to-paid conversion rather than top-of-funnel volume.

## 8.3 Lifecycle & Expansion Marketing

Marketing does not stop at signup. Because the product itself is a five-tier ladder, automated lifecycle messaging nudges a Free assessment toward Starter, and Starter or Growth clients toward Guided or Managed as their compliance needs deepen — a new contract requiring SOC 2, an insurance renewal, a CMMC deadline. This internal, expansion-focused marketing is as important as external acquisition, since upgrading an existing client requires far lower cost than winning a new logo, and it is the mechanism behind the Section 6 client-mix shift toward higher tiers over time.

## 8.4 Metrics & Marketing Discipline

Every channel is tracked on customer acquisition cost (CAC), free-to-paid conversion rate, tier-upgrade rate, and payback period. Underperforming channels are cut within a quarter rather than scaled on hope. Given the client ramp modeled in Section 6 (170 → 610 → 1,610 paying clients across three years), the strategy is deliberately built to diversify beyond any single channel by Year 2 — broker and association partnerships are relationship-built and slower to scale but far more durable and lower-cost than paid acquisition, which is why they are prioritized first even though they take longer to activate.

# 9. Product Roadmap & Future Vision

## Phase 1 — Live Today: The Self-Serve Product

- Conversational intake + structured NIST checklist; deterministic posture scoring.
- AI-generated security program: roadmap, policies, compliance mapping, workflows, training, executive report.
- Professional policy generation with Word export; five-tier billing infrastructure; read-only cross-platform monitoring agent; Mastermind Q&A live at Starter tier and up.

## Phase 2 — This Raise: The Managed Platform

- Convert the analyst console from mockup to live (portfolio view, per-client command centers).
- Bring the first cybersecurity engineer on full-time — including converting our existing part-time engineer (see Section 10) — and hire additional engineering support.
- Live Mastermind AI co-pilot for engineers, in production; review-and-approval workflow live.
- Client messaging, weekly automated program reporting, and compliance progress tracking.

## Phase 3 — Scale: Telemetry & Automation

- Deploy network agents in client environments for live posture and threat telemetry — permanently read-only, with no inbound command channel.
- Continuous monitoring, automated alerting, and agent-fed recommendations, always routed through human review.
- Channel partnerships (insurers, MSPs, trade associations — see Section 8) for low-CAC distribution; expand client base and verticals.

## Phase 4 — Expanding AI Autonomy & Feature Depth

Beyond this raise, two future directions extend the platform — both are additive to the trust model in Section 4.3 and Section 12, not a departure from it.

### More autonomous AI, within the same human-approval gate

Today, AI analysis and generation happen when a client or engineer requests them. The next evolution is AI that works more continuously and independently on the analysis and drafting itself: continuously re-scoring posture as new agent telemetry or threat intelligence arrives rather than waiting for a manual trigger, autonomously drafting updated policies or remediation steps in response to a new threat or a configuration change, and proactively surfacing emerging risks to the assigned engineer before a client has to ask. In every case, this is autonomy in what the AI analyzes, drafts, and recommends — never in what it is permitted to do unilaterally in a client's environment. The human-approval gate before anything ships to a client, or changes anything in their systems, is a permanent trust and liability boundary (Section 12), not a temporary technical limitation we intend to remove.

### Feature depth that meets — and beats — the compliance-automation category

Section 7 shows that Vanta, Drata, Secureframe, and Scrut Automation have built genuinely sophisticated automation — deep cloud and SaaS integrations, continuous evidence collection, broad framework libraries. ShieldAI's roadmap explicitly targets matching that automation depth: expanding integrations for continuous evidence collection where a client does have a cloud stack, broadening framework coverage further, and speeding generation and remediation cycles. The difference is not that we build less — it's that we deliver the same or greater automation depth at a

fraction of the price, with the human-reviewed program and direct-to-SMB distribution those platforms don't offer. Better versions of the category's best features, on our foundation, not instead of it.

## 10. Founder & Team

### 10.1 Founder — Derrick Brooks



**Derrick Brooks**

*Founder & CEO, Xandu Limited, LLC*

Former U.S. Navy Lieutenant Commander · 20+ years in risk management, compliance, and IT infrastructure · CISSP · CISM · CompTIA Security+

Derrick Brooks is the founder and CEO of ShieldAI, built under Xandu Limited, LLC. A former U.S. Navy Lieutenant Commander with over 20 years in high-stakes risk management, compliance, and IT infrastructure, he has built enterprise security programs from the ground up, administered budgets exceeding \$200,000, and led cross-functional teams of up to 195 personnel — consistently delivering measurable results, including attack-surface reductions of up to 80% through Zero Trust architecture, Azure cloud migration, and automated vulnerability management.

Critically for a security founder, Derrick is not only a strategist but a hands-on practitioner. He has conducted penetration testing across enterprise web applications, cloud infrastructure, and connected-device APIs, uncovering and remediating tens of thousands of vulnerabilities for organizations including a major automotive manufacturer. This offensive fluency, paired with mastery of the compliance frameworks that drive buying decisions — NIST, RMF, CMMC, ISO 27001, and FedRAMP — means he understands both what the product must do technically and why customers will pay for it.

Credentials: CISSP, CISM, CompTIA Security+. Dual M.S. in Cybersecurity (National University); MBA in IT Management (Southern New Hampshire University); doctorate in Cybersecurity in progress (Westcliff University) — reinforcing frontline experience with ongoing academic research and keeping ShieldAI positioned at the leading edge of the field.

The market opportunity is structural: enterprise-grade security leadership has long been priced out of reach for the millions of small and mid-sized businesses that face the same threats as large enterprises but lack a CISO. Derrick's disciplined military leadership, proven ability to build and scale teams, and rare command of the full security stack — from boardroom strategy to code-level execution — position him to build a category-defining company and give investors confidence in both the vision and the execution behind it.

### 10.2 Team & Near-Term Hiring

ShieldAI is being built by Xandu Ltd. The product is already developed and functioning, demonstrating execution capability and meaningfully de-risking the technical plan.

Alongside Derrick, ShieldAI already has a part-time security/software engineer contributing to the codebase today, who is prepared to convert to a full-time role immediately once this raise closes. This means the first security engineer hire funded by Section 11's Use of Funds is not a cold search — it is activating a known, already-embedded technical resource, which meaningfully de-risks the Phase 2 hiring plan relative to a founder hiring cold into an unfamiliar codebase.

Because the platform model amplifies each engineer with AI, the team can stay lean relative to the size of the client book it supports. Security leadership and qualified engineering talent remain the key priority hires, given that the managed offering depends on credible, accountable human expertise.

## 11. The Ask & Use of Funds

ShieldAI is raising \$900,000 in seed funding to fund the transition from a working self-serve product to a managed-security platform over the next 18–24 months.

| Use of Funds                                                                                             | Amount           | %   |
|----------------------------------------------------------------------------------------------------------|------------------|-----|
| Engineering (analyst console to live + network agents)                                                   | <b>\$320,000</b> | 36% |
| First security engineers (2–3 hires — including converting our existing part-time engineer to full-time) | <b>\$280,000</b> | 31% |
| Go-to-market & channel partnerships (Section 8)                                                          | <b>\$180,000</b> | 20% |
| Operations, SOC 2, legal & compliance                                                                    | <b>\$90,000</b>  | 10% |
| Working capital reserve                                                                                  | <b>\$30,000</b>  | 3%  |

This capital takes ShieldAI to Series A readiness in the Month 22–24 window: a managed-services platform in production, the first cohort of engineers running client programs, an ARR run-rate crossing \$3M, and proven managed-tier retention and unit economics. Under the accompanying financial model, the raise is never fully exhausted — modeled cash bottoms out around \$130,000 near Month 18 before the business turns cash-flow positive.

*A full-time CISO costs a quarter-million dollars a year. ShieldAI delivers that protection for the price of a subscription — and the platform lets a handful of our engineers protect thousands of businesses.*

## 12. Risk Analysis & Mitigation

| Risk                                                                                            | Mitigation                                                                                                                                                                                                                                     |
|-------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>AI output accuracy / hallucination</b>                                                       | Deterministic scoring engine for the trust-critical number; human engineer reviews and approves all client-facing deliverables before release.                                                                                                 |
| <b>Liability if a managed client is breached</b>                                                | Human-in-the-loop accountability; clear scope and terms on the self-serve tiers; appropriate professional and cyber insurance; SOC 2 posture.                                                                                                  |
| <b>Well-funded competitor (e.g., Cynomi's \$37M Series B, or a Vanta/Drata SMB-tier launch)</b> | Differentiate on proprietary scoring methodology, the managed services + platform model, direct-to-SMB distribution, and accumulated data and relationships rather than the AI alone — see Section 7.5 for the full landscape and watch items. |

| Risk                                                             | Mitigation                                                                                                                                                                                                                                                       |
|------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>AI API cost or terms change</b>                               | Model-flexible architecture; proprietary logic and scoring sit above any single provider; substitute models as needed.                                                                                                                                           |
| <b>Customer churn (security feels done)</b>                      | Managed plans and continuous monitoring make the program perpetually valuable; compliance cycles and reporting anchor retention.                                                                                                                                 |
| <b>Scaling human expertise</b>                                   | The analyst console + AI co-pilot are designed precisely so each engineer manages many clients without linear headcount growth.                                                                                                                                  |
| <b>Expanding AI autonomy erodes trust or increases liability</b> | The Section 9 autonomy roadmap is explicitly scoped to analysis, drafting, and detection — never to unilateral action in a client's environment. The human-approval gate is treated as a permanent architectural boundary, not a milestone to eventually remove. |

## 13. Summary

ShieldAI addresses a large, underserved, and — critically — a forced-demand market: tens of millions of small businesses that now must demonstrate a real security program but cannot afford to staff one. We enter with an affordable, working self-serve product and expand into high-value managed programs delivered by cybersecurity engineers who are amplified by our software and AI co-pilot.

Our defensibility is a system, not a feature: a proprietary, explainable NIST scoring engine; a human-in-the-loop model that makes our output trustworthy enough to sell; the data and relationships that compound with every client; and direct-to-SMB distribution that the five best-funded names in the category — Cynomi, Vanta, Drata, Secureframe, and Scrut Automation — have each left structurally uncontested. A deliberate marketing strategy built on high-intent, relationship-driven channels (Section 8) and a roadmap that expands AI autonomy and feature depth without ever compromising the human-approval boundary (Section 9) extend that defensibility forward.

The product is already built, the founder brings a rare combination of operational, executive, and technical security credibility, and a technical co-founder-level engineer is already in motion, ready to go full-time on day one of this raise. This fundraise funds the platform layer that turns a working product into a scalable business.